



SCHOOL HOMEWORK - 2023

CLASS : APPLICATION SECURITY

SUBJECT : DATAFLOW DIAGRAMS, THREAT MODELING AND RISK
ASSESSMENT IN APPLICATION SECURITY WITH STRIDE FRAMEWORK

FRÉDÉRIC PERRON

Details of the homework

Objective

This homework will aim to put into practice the concepts seen in class concerning threat modeling using the STRIDE method.

Steps for completion

Here is a summary of the problem:

A company in the automobile and home insurance sector has made a website available to its clients to allow them to open a claim file following an incident.

The site allows a client holding an insurance policy to register, fill out the form, and describe the incident to proceed with the claim processing.

The main points :

1. The site ACME.com (French) allows insured clients to open a claim request and lets claims investigators consult a file.

FORMULAIRE DE DEMANDE D'ENQUÊTE

Les champs identifiés par un astérisque (*) sont obligatoires.

Identification du demandeur

* Je suis... ☒ Personne du public ☐ Agent d'enquête

* Sexe: ☒ Féminin ☐ Masculin ☐ Prétère ne pas répondre

Prénom*	Nom*
Adresse (no, rue, bur /app.)*	Ville*
Code postal*	Choisir... - Choisir un pays* -

*Indiquer au moins un numéro de téléphone où vous pouvez être joint entre 9 h 00 et 17 h 00

Téléphone maison	Téléphone travail	Poste
Téléphone cellulaire	Courriel (vous recevrez un accusé de réception avec le détail de votre demande)*	

Identification du(des) co-demandeur(s)

Nombre de co-demandeur (min. 0 - max. 10)

Description des événements survenus et identification des témoins

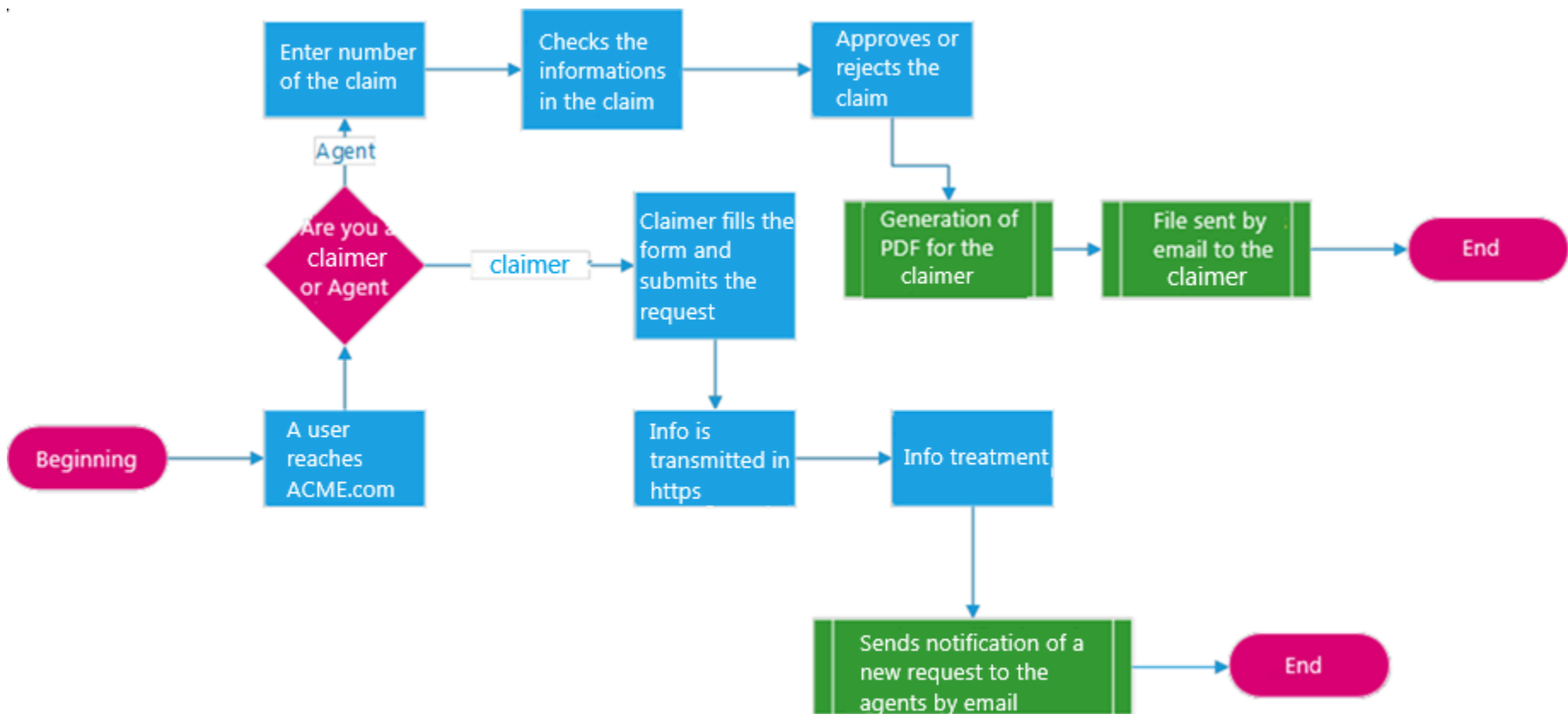
* Résumé des faits (indiquez les dates et lieux):

Nombre de témoins (min. 0 - max. 10)

Documents appuyant les allégations?

Document: Aucun fichier sélectionné. (Document format: Word ou Pdf, Taille maximum: 1 Mo)

3. The insured then sends the completed form via an HTTPS channel to the insurance company.
4. It can be assumed that the company stores the received information in database servers and uses a three-tier architecture.
5. Once completed, the request is sent to the agent.
6. After a certain period, usually no more than three business days, the insured receives by email a PDF file containing the status of their claim.
7. This PDF file is attached, and the email contains confidential information. It includes the following details:
 - a. A claim tracking number
 - b. First name, last name, address, policy number, driver's license number, date of the incident, claim history, etc.
8. An investigation agent can also view the status of the claim from the same website.
9. Here is an overview of the process:



Must do

A report containing the following sections:

1. State of the situation: introduction, hypothesis/assumptions, etc.
2. A DFD (Data flow diagram)
3. Possible attack vectors (STRIDE)
4. Risk level
5. Solutions and proposed recommendations

NB :

1. An individual report (ou par groupe de max 3).
2. The report in Word or PDF

Detailed answers

Table of contents

Introduction :	4
Question 1 : State of the situation : Assumptions or other relevant observations, etc.	5
Question 2 : a DFD (Data flow diagram)	7
Question 3 : Possible attack vectors (STRIDE)	8
Question 4 : Risk level.....	13
Question 5 : Solutions and proposed recommendations.....	15
Conclusion :	17

Introduction :

The completion of various tasks within an organization generally requires the use of diverse data within a computerized information system.

However, this system is often exposed to technical failures (breakdowns), malware intrusions, or simply user errors. The data collected, stored, and exchanged within the corporate network are confidential. This therefore requires companies to ensure control over their infrastructure.

A corporate network involves several components that ensure communication and data exchange among internal and external stakeholders. Securing this network means optimizing the condition and operation of its components to protect against cyberattacks and incidents caused by misuse, with the aim of safeguarding data.

ACME, being a company operating in automobile and home insurance, is required to comply with the laws of the countries where it operates, notably Law 25 for Quebec (Personal Information Protection Act LQ 2021, c 25), and to provide a service available 24/7 all year round.

Assuming the company stores the received information on database servers and uses a three-tier architecture, this architecture must comply with the three core principles of security, known as the CIA triad:

- **Availability:** Access to information system resources must be continuous and flawless during scheduled use periods. Services and resources should be quickly and reliably accessible.
- **Integrity:** Data must be what is expected and must not be altered accidentally, unlawfully, or maliciously.
- **Confidentiality:** Only authorized persons may access information intended for them. Any unwanted access must be prevented.

Other aspects can also be considered as information security objectives, such as traceability (or “proof”), non-repudiation, and authentication.

To meet these requirements, our report will include a contextual introduction with assumptions, a Data Flow Diagram, identification of possible attack vectors based on threat modeling using the STRIDE method, and finally an evaluation of risk levels with proposed solutions and recommendations.

See (amount points) of each question in the correction table on annexe B

Section 1

Questions :

Answers and print screens of different steps

Question 1:
State of the situation:
Assumptions or other relevant observations, etc.

Context

ACME operates in the automobile and home insurance sector and uses the website ACME.com to exchange client information. Its IT architecture follows a three-tier model.

ACME's infrastructure mainly consists of database servers, application servers, networking equipment, and employees.

A web interface (HTTPS channel) is used for access by both clients and investigators.

PDF files are used for communication.

ACME exchanges data both internally and externally (with clients and investigators).

The processing time for requests is a maximum of three business days.

Overview: Presentation of the Three-Tier Architecture

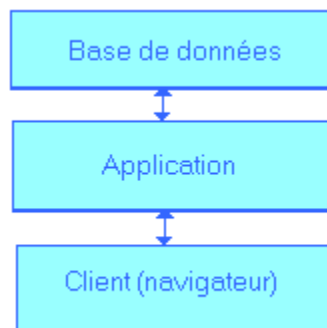
ACME's architecture is a three-tier architecture, divided into three levels:

Presentation layer:

Application layer:

Database layer:

This model separates the application into three software layers:



Application (or middleware): handles the logical and application-level processing of the data.

Client (browser): displays and presents the data, forming the interface with the customer.

Source : https://fr.wikipedia.org/wiki/Architecture_trois_tiers

Each layer communicates only with its immediate neighboring layers. In this model, a layer is not allowed to communicate with any layer lower than the immediate one below it, nor higher than the immediate one above it. The layers interact through an exchange model and provide sets of services.

Each layer has a well-defined role and can evolve independently without imposing changes on the other layers.

The three-tier architecture allows:

Platform heterogeneity (Windows, Linux, etc.)

Improved data security by removing the direct link between the client and the databases

Better load distribution among different application servers

Definitions of the three tiers:

First tier – Presentation

This is the interactive and visible part of the application for clients. This interface is represented in HTML to be used by a web browser (Internet Explorer, Edge, or Chrome).

This tier sends client requests to the application layer and, in return, presents the information returned by the application.

Second tier – Application

This is the functional part of the application that implements the logic. It describes the operations the application performs on data based on client requests sent from the presentation layer.

It provides application services to the presentation layer. To offer these services, it uses data from the database system, accessible via the lower tier. In return, it sends the processed data results back to the presentation layer. This layer includes the open-source middleware used for client data.

Third tier – Database

This part manages access to the database data. These data are transparent, and the application layer accesses them uniformly (loosely coupled).

This layer includes data of policyholders, client data, and investigator agents stored in a dedicated database, as well as another database that includes backups.

Issues:

ACME, being an insurance company that processes its clients' requests via its website ACME.com, must comply with certain requirements such as:

- Maintaining service availability 24/7, every day of the year

- Data protection: ACME is responsible for protecting the personal data of its clients, employees, business partner agencies, and the organization itself

- Ensuring the protection of its physical, hardware, and application infrastructures; ACME must guarantee the security of its IT system applications and the physical security of its infrastructures

- Ensuring compliance with client and supplier contracts

- Meeting requirements set by stakeholders (employees, internal and external clients, investigation companies), including processing deadlines, tracking, and claims payments

-Maintaining credibility and preserving its brand image

Hypothesis/Assumptions

ACME may face various scenarios, including the following:

- Data theft or leaks (both internal and external)
- Service outages due to failure (software or hardware) or cyberattacks (denial of service, phishing, etc.)
- Identity theft of clients, fraud
- Application vulnerabilities due to unpatched software
- Virus infections
- Outdated systems and applications
- Risks of financial loss and damage to the company's reputation

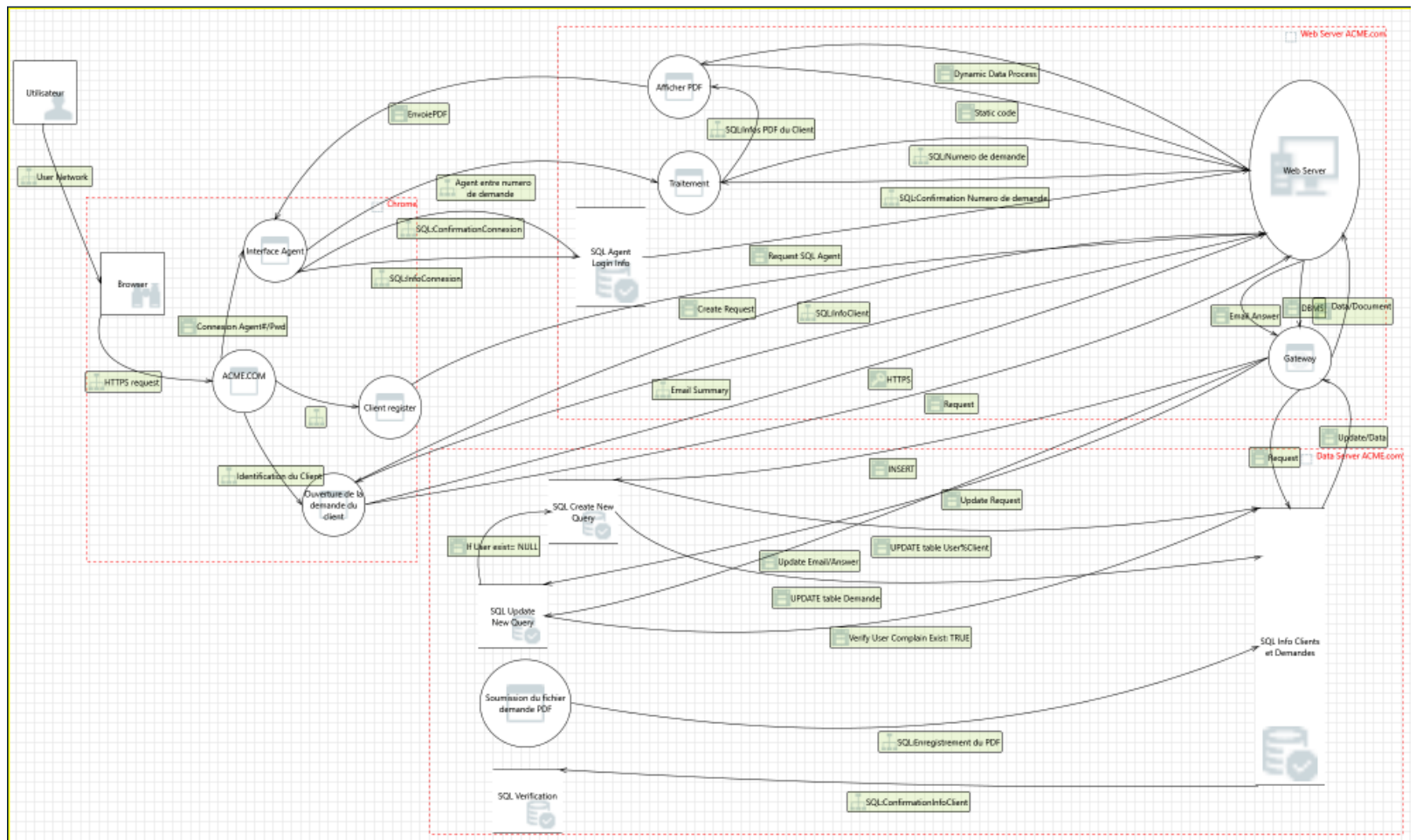
Note: Some assumptions will appear in the STRIDE model; we will use them to assess risks and find possible solutions.

Question 2 : a DFD (Data flow diagram)

The data flow diagram must fulfill several functions, including:

- 1.System connection, accessed via the internet using an HTTPS link
- 2.Account creation (Name, password, date of birth range, etc.)
- 3.Login (username, password, policy number, etc.)
- 4.Request types (submission, claim, tracking)
- 5.Data recording/modification
- 6.Database consultation, client information (policy number, request type, history, contract, etc.)
- 7.Acknowledgment of receipt (email and request number)
8. Logout

Considering the three-tier architecture, we can derive the following Data Flow Diagram (DFD):



Data Flow Diagram of ACME

Question 3 : Possible attack vectors (STRIDE)

Spoofing

Identity spoofing is when a machine or a human tries to impersonate another machine or person in order to deceive them and gain their trust, with the goal of stealing sensitive data or using IT resources to carry out further attacks. (Softwarelab.org, 2022)

In our case, if we refer to the S.T.R.I.D.E. method, the risks to consider are:

- A machine or person could impersonate an insurance agent or a policyholder.
- The DNS of the ACME.com website could be hijacked and redirected to a fraudulent site (fake forms)
- IP address spoofing or server impersonation.
- Email Spoofing
- Spoofing a HTTPS channel
- Trojan horse embedded in the PDF file (can hide malware intended to launch further attacks).
- Cybercriminals can access the company's local network by sending fake ARP (Address Resolution Protocol) Data. By associating their MAC address with a legitimate IP address, attackers can steal sensitive data.
- Unauthorized access may be granted to an attacker posing as an ACME client.

Tempering

Data tampering is the act of accessing and modifying or even deleting resources—such as sensitive information or source code—without authorization (OWASP, 2022). In our case, this could include:

- Modification of client data (date of birth, name, address, SIN). This can be done by an attacker not directly linked to ACME, or by a policyholder trying to alter their file to gain an advantage (e.g., changing the compensation amount or insured assets).
- Modification of the claim form and PDF files.
- Tampering with the site's database
- Data injection into the site's SQL database.
- Physical damage to the server
- A malicious user sends executable code (script) (Menoth, 2018)
- Redirection of the site's URL.

- Requests can be intercepted by an attacker and, depending on the type of data, may be used to attack other parts of the system or lead to compliance violations.
- Malicious scripts (XSS) could be injected by an attacker.
- An attacker may take control of a gateway within the network.

Repudiation

Repudiation is when a person claims not to have performed an action. The person may claim not to have received or sent certain information during a transaction or communication over a network (Menoth, 2018). In our case, this could involve:

- A policyholder may claim to have never submitted a claim.
- An agent may claim to have never viewed a form, thus denying access to someone's information.
- A policyholder may claim to have never received the confirmation PDF or email.
- A policyholder may deny a past incident.
- An agent may claim to have never received the policyholder's form.
- An agent could falsely claim they processed a claim when in fact it was never done.
- An attacker could attempt to alter the logs to erase their tracks.
- An attacker might use a fake email address to intercept information and make it impossible to trace back to them.

Information disclosure

Information disclosure can occur either intentionally or unintentionally. It generally happens when encryption processes or updates have not been properly followed, leaving vulnerabilities that can be exploited to access sensitive

information. In the case of information disclosure, the attacker gains access to an information system or a specific application platform with the goal of stealing sensitive data — such as software distribution details, version numbers, and patch levels. The collected information may also include the location of backup files or temporary files. (PortSwigger, 2022)

- A policyholder or hacker could try to access another policyholder's account and view their personal information such as name, address, policy number, driver's license number, date of the incident, claim history, etc.
- A hacker could gain access to ACME's website database.
- Access to unencrypted information.
- A man-in-the-middle attack to intercept the claim form or the PDF containing the request status.
- Unauthorized access to the user password database.
- A misconfiguration could unintentionally expose sensitive information to website users.
- Disclosure of source code and backup files.
- An attacker could try to intercept communications between clients and agents.

Denial of service

Denial of service occurs when a platform (website, application, server, protocol, etc.) can no longer respond or, in other words, perform the task it was designed for because it is overwhelmed with requests, which interrupts or disrupts a service. In the case of the company ACME, it is possible that:

- The site crashes due to intensive requests from zombie computers controlled by a hacker, making the site inaccessible to clients and agents.

- A disaster (natural catastrophe, accident, power outage) could occur and affect the site's servers.
- Disruption of the company's network configuration by a hacker (ARP poisoning).
- A hacker could prevent a client from communicating with an agent by redirecting their messages (ICMP redirect).
- An administrator could interrupt the service by modifying system settings or configurations (Houes, 2018).
- Web server crash or slowdown preventing clients from accessing the site.
- If an attacker gains access to limited resources such as memory, file system storage, connection pool entries, databases, or the CPU, they could trigger a denial of service by consuming all available resources. (CWE, 2022)

Elevation of privilege

Privilege escalation occurs when a person attempts to gain higher privileges than those normally granted to them, in order to access sensitive information or modify system settings (Geekflare, 2022). In the case of the company ACME, it is possible that:

- A malicious agent attempts to modify their permissions to gain administrator privileges on ACME's web server.
- A hacker, after authenticating as a legitimate company user, could modify their permissions to access sensitive information.
- Exploitation of accounts with low security levels.
- A client could exploit vulnerabilities and attempt privilege escalation using social engineering.
- An attacker can send data to modify the program's execution flow.
- Modification of the program's execution flow by an attacker.
- Poor password management could allow a malicious person to access a high-privilege account.

➤ Privilege accumulation by an administrator.

Question 4 :
Risk level

Risk analysis allows us to evaluate the impacts that a system, an application, threats, and the environment (laws, requirements, etc.) can have on the activities of a company or organization.

These risks can be assessed by considering several factors: the environment, financial losses, threats, service commitments, and the criticality of equipment and applications.

It also depends on the type of solution the company chooses to deliver services to its clients.

The company may choose service outsourcing, where equipment is hosted in the cloud, and the responsibility for applications and systems is entrusted to a service provider who guarantees the quality of the service. The company then monitors compliance with the contract (SLA - Service Level Agreement), which tracks outages and performance.

Alternatively, the company may be responsible for its own infrastructure and applications, in which case it has full responsibility for these services. Risk analysis here takes into account the systems and applications directly managed by the company.

In both cases, the threats at the service level remain the same because many things remain transparent to the client, who only demands a reliable service. However, the company's approach to risk management differs.

Since ACME is an insurance company, the direct consequences of these impacts will be felt on its profits, reputation (public opinion), and customer satisfaction.

We will evaluate risks using four levels of severity: Critical, Major, Medium, and Minor. These severity levels correspond to scores based on Availability, Integrity, and Confidentiality (AIC), which have a direct impact on the service provided to both internal and external clients.

Risks related to threats

Threats					
	Disponibility	Integrity	Confidentiality	Score	Comments
Authentification		3	5	8 (Critical)	Vulnerability causes access to clients' accounts, data modification, fake claims, etc....
Denial of service	5	1	1	7 (Critical)	No service possible
Identity Usurpation		3	5	7 (Critical)	Difficulty or no service, image and finance
Data Breach		4	5	9 (Critical)	Image of ACME, risks of getting sued by those clients, financial loss

Repudiation		1	1	2(Minor)	Can be done by clients, but ACME needs to keep logs, clients don't have access
Elevations of privileges		5	3	8 (Critical)	Can be done by an employee, or during a cyberattack to modify data, inject code or virus or just make the system unavailable
DNS attack	4	3	1	8 (Critical)	Can be done by cyberattackers to bypass the site to another link or just make it unavailable
Virus	4	3		7(Critical)	Can cause outages, slowed systems, unavailability of service
Phishings	2	2	2	6 (Major)	An employee or a client can be victim by email

Risks related to systems and applications

Assets	Disponibility	Integrity	Confidentiality	Score	Comments
Database Server	5	5	5	15 (Critical)	No service possible (no access to data)
Application Server	5	4	4	13 (Major)	Difficulty or no service, image and finance
Web Server	5	4	4	13 (Major)	Difficulty or no service, image and finance
Adobe	3	3	3	9 (Medium)	Difficulty of service, image
Java	4	3	3	10 (Medium)	Difficulty of service, image
Internet	5	1	1	7 (Minor)	Doesn't rely on ACME
Account Client	5	2	3	10 (Medium)	Shared responsibilities
Account Employee	5	4	4	13 (Medium)	Responsibilities ACME
Account Agency	5	3	3	11(Medium)	Shared responsibility

Risks related to threats impact parts of the service to varying degrees but rarely affect the entire service simultaneously—except for denial of service (DoS) attacks, which can cause complete service unavailability.

	Clients will lose access to the service during such outages, and the reliability of the service will be compromised, leading to reputational damage and subsequent financial losses. At the IT infrastructure level (servers and applications), the risk levels are very high because these components are central to ACME's operations. They have a significant impact on revenue, company image, and compliance with commitments. Their vulnerabilities are intolerable since client data protection depends on them. Physical protection of these infrastructures also deserves strong attention. Given the service delivery time frame of three days, ACME has some operational flexibility in case of application downtime, but this will affect service quality (availability), thus damaging ACME's reputation and directly impacting customer loyalty. Regarding access (accounts for clients and employees), ACME's primary responsibility is to provide access only to authorized persons, protect those accounts, and maintain traceability of account activity. However, users also share responsibility for protecting their accounts (e.g., passwords and user codes). ACME can only block account access upon detecting fraudulent attempts (such as authentication failures) or upon client request after proper authentication. Thus, responsibility for account security is shared between ACME and its clients. Data is ACME's most sensitive resource needed to conduct business effectively. It must be available, confidential, integral, and traceable, hence considered critically risky. Since data is managed by platforms, servers, applications, and accounts, the risk levels of these components directly influence data security and access. Not all risks can be eliminated, but following best practices allows their impact to be mitigated.
Question 5 : Solutions and proposed recommendations	Solution Approaches ACME provides a service platform to its clients. This platform must be secure and available to meet its commitments. We recommend the following solutions: - User Authentication: Before any access to the service or insurance policy, the client must be authenticated using a unique login, with a username and a well-encrypted password. Password policies should enforce length, complexity, and limit the number of login attempts. Alternatively, use Multi-Factor Authentication (MFA), which is very secure as the user provides proof of identity recognized by the system. - Secure the URL with HTTPS: Although HTTPS is known to be secure, it still has vulnerabilities when using SSL. ACME must activate the more secure TLS protocol on its servers. - Keep applications updated: Ensure timely updates from providers (patches, antivirus, software updates) to avoid virus attacks and exploitable application vulnerabilities. - Redundancy of critical systems: Duplicate critical components like application servers, databases, and network systems to ensure service continuity in case of hardware failures, thus maintaining service availability. - Prevent privilege escalation: Implement an Identity and Access Management (IAM) policy with clearly defined rights and access for clients and employees based on roles and responsibilities. Conduct periodic access reviews and use RSA keys for employee authentication.

- | | |
|--|---|
| | <ul style="list-style-type: none">- Protect systems and applications: Use firewalls, antivirus software, and regularly update system and application software to reduce vulnerabilities. Keep track of software licenses with providers.- Backup data: Regular backups enable system restoration after crashes or data loss, preventing data loss.- Audit ACME's infrastructure and procedures: Audit the IT management system, user access, databases, etc., to identify weaknesses and ensure compliance.- Event logging: Maintain detailed logs for traceability of all events (client and employee accounts, outages, applications). This helps prevent repudiation and provides good monitoring of client and employee activities.- Staff training: Train personnel to avoid vulnerabilities like phishing, unauthorized access, and improper handling of client data.- Ensure clear contracts and define roles and responsibilities of all stakeholders (clients, employees, management). For example, the client is responsible for the confidentiality of their account (password protection, etc.).- Data classification based on sensitivity (Confidential, Secret, Top Secret, Unclassified). Each party knows exactly what data they are authorized to access, which helps guarantee confidentiality.- Establish a crisis and major incident management unit, responsible for procedures, actions, and communication in case of significant incidents. |
|--|---|

Conclusion :

Risks, requirements, and responses to cybersecurity vary depending on an organization's IT architecture and structure, but organizations within the same sector generally face similar threats.

Since ACME operates in the insurance sector, data is one of its most critical resources to protect. Ensuring its protection involves securing the infrastructure and applications that support it but also requires strong procedures and policies for data management, including data classification and access control.

Our study evaluated ACME's production system using the STRIDE threat modeling method, identified possible vulnerabilities, made assumptions, conducted a risk analysis, and proposed solutions to help secure its systems and applications.

Cyber attackers are constantly improving their techniques to discover and exploit security flaws in information systems. As a result, ACME must regularly adjust to maintain an adequate level of protection for its systems and applications. This includes closely managing supplier contracts, staying informed about industry innovations, and training its staff on cybersecurity threats.

We can conclude with the following statement:

"Cybersecurity risks always exist, but they can be mitigated with best practices."

References :

- Moes, T. (2022, 1 octobre) *What is a Spoofing Attack? The 5 Examples You Need to Know*. Softwarelab.org. <https://softwarelab.org/what-is-spoofing/>
- Menoth, R. (2018, 18 janvier) *Comprendre le modèle "STRIDE"*. Microsofttechnet. <https://social.technet.microsoft.com/wiki/contents/articles/51078.comprendre-le-modele-stride-fr-fr.aspx>
- Common weakness Enumeration. (2022, 28 juin). *CWE-400: Uncontrolled Resource Consumption*. <https://cwe.mitre.org/data/definitions/400.html>
- Haoues, M (2018, 2 mai) *Déni de services distribué [notes de cours]*. Département de cybersécurité. Polytechnique https://moodle.polymtl.ca/pluginfile.php/937846/mod_resource/content/0/CY110%20Cours5%20200205.pdf
- OWASP Foundation, (2017, 1 octobre). *A5:2017-Broken Access Control*. https://owasp.org/www-project-top-ten/2017/A5_2017-Broken_Access_Control
- OWASP Foundation, (2017, 5 octobre). *A3:2017-Sensitive Data Exposure*. https://owasp.org/www-project-top-ten/2017/A3_2017-Sensitive_Data_Exposure
- OWASP Foundation, (2022, 5 octobre). *Web Parameter Tampering*. https://owasp.org/www-community/attacks/Web_Parameter_Tampering
- OWASP Foundation, (2022, 5 octobre). *Repudiation Attack*. https://owasp.org/www-community/attacks/Repudiation_Attack
- Geek Flare, (2022, 1 octobre). *Attaques d'escalade de privilèges, techniques et outils de prévention*. <https://geekflare.com/fr/privilege-escalation-attacks/>
- Portswigger (2022, 1 octobre). *Information disclosure vulnerabilities*. <https://portswigger.net/web-security/information-disclosure>
- Hewko, A. (2022, 5 octobre). *Softwaresecured. STRIDE Threat Modeling: What You Need to Know*. <https://www.softwaresecured.com/stride-threat-modeling/>

<https://www.ooaq.qc.ca/espace-membres/nouvelles/que-faut-il-savoir-loi-25/>

<https://www.techno-science.net/definition/5266.html>

https://fr.wikipedia.org/wiki/Architecture_trois_tiers

<https://softwarelab.org/>

<https://www.nist.gov/cyberframework>

Le CISSP Démystifié Edition 2020 de Zakaria Hadj, CISSP